

Защита контроллера домена предприятия

**Расследование и устранение последствий инцидента на
киберполигоне Ampire**

Назармамадов Умед Джамshedович

В отчёте представлены результаты выполнения лабораторной работы №1 по курсу «Защита сетей и кибербезопасность» на киберполигоне Ampire (сценарий №2 «Защита контроллера домена предприятия»).

С использованием систем ViPNet IDS NS и ViPNet TIAS проведено расследование трёхэтапной атаки на корпоративную сеть: SQL-инъекция в веб-портал, компрометация рабочей станции администратора через фишинг и захват контроллера домена методом перебора пароля. Для каждого этапа атаки найдена уязвимость, заполнена карточка инцидента и выполнено устранение последствий на поражённом узле.

Сделаны выводы об эффективности применённых мер реагирования и сформулированы рекомендации по повышению защищённости инфраструктуры.

Содержание

1	Введение	6
1.1	Актуальность	6
1.2	Цель работы	6
1.3	Задачи	7
1.4	Объект и предмет исследования	7
1.5	Методы исследования	7
1.6	Схема выполнения работы	8
2	Теоретическая часть	10
2.1	Сценарий атаки	10
2.2	Топология сети полигона	11
2.3	Используемые средства мониторинга	11
3	Материалы и методы	12
4	Выполнение лабораторной работы	13
4.1	Уязвимость 1. SQL-инъекция на веб-портале	13
4.2	Уязвимость 2. Отключённая антивирусная защита на рабочей станции администратора	16
4.3	Уязвимость 3. Перебор пароля администратора домена и добавление привилегированного пользователя	20
5	Результаты	25
6	Обсуждение результатов	27
7	Заключение	28

Список иллюстраций

1.1	Блок-схема выполнения лабораторной работы	9
4.1	Событие ViPNet IDS NS: ET SCAN Sqlmap SQL Injection Scan, источник sqlmap/1.7.2	13
4.2	Источник события: IP 195.239.174.11, геолокация Россия, Москва	14
4.3	Карточка инцидента №1: SQL-инъекция на веб-портале	15
4.4	Событие ViPNet IDS NS: ET TROJAN Possible Metasploit Payload Common Construct Bind_API	17
4.5	Источник события: 195.239.174.11, порт 444	17
4.6	Получатель события: Administrator Workstation 10.10.4.10, порт 50162	18
4.7	Карточка инцидента №2: компрометация рабочей станции администратора	19
4.8	Событие ViPNet IDS NS: ET POLICY MS Remote Desktop Administrator Login Request, 29 событий за 10 секунд	21
4.9	Источник события: 10.10.1.20 (ранее скомпрометированный Web Server PHP)	21
4.10	Получатель события: MS Active Directory 10.10.2.10, порт 3389 . .	22
4.11	Карточка инцидента №3: перебор пароля администратора домена	23

Список таблиц

2.1	Этапы атаки по сценарию №2	10
5.1	Итоговые статусы устранения уязвимостей	25

1 Введение

1.1 Актуальность

Своевременное обнаружение и реагирование на инциденты информационной безопасности — одна из ключевых задач защиты корпоративной сети. Атака на контроллер домена — особенно критичный сценарий, поскольку компрометация Active Directory даёт злоумышленнику полный контроль над всей доменной инфраструктурой предприятия. Отработка полного цикла реагирования (обнаружение → фиксация → устранение → подтверждение) на киберполигоне позволяет закрепить практические навыки работы с системами мониторинга (ViPNet IDS NS, ViPNet TIAS) и инструментами администрирования Windows/AD в условиях, приближенных к реальным.

1.2 Цель работы

Расследовать инцидент информационной безопасности на киберполигоне Ampire по сценарию №2 «Защита контроллера домена предприятия»: обнаружить все этапы атаки по данным системы мониторинга, задокументировать их в виде карточек инцидентов и устранить последствия на каждом поражённом узле.

1.3 Задачи

- Изучить топологию сети полигона и сценарий атаки.
- С помощью ViPNet IDS NS обнаружить и проанализировать события, соответствующие каждому этапу атаки.
- Для каждой обнаруженной уязвимости завести карточку инцидента с указанием источника, поражённого актива, индикаторов компрометации и рекомендаций.
- Устранить техническую причину и последствия каждой уязвимости непосредственно на поражённом узле.
- Подтвердить устранение по статусу уязвимости на панели полигона.

1.4 Объект и предмет исследования

Объект исследования — сегмент корпоративной сети киберполигона Ampire (DMZ, Data Center, сегмент офисных пользователей). Предмет исследования — цепочка компрометации «внешний веб-сервер → рабочая станция администратора → контроллер домена» и методы её обнаружения и нейтрализации.

1.5 Методы исследования

- Анализ сигнатурных событий системы обнаружения вторжений ViPNet IDS NS.
- Администрирование Linux (su, grep, find, nano, ss) для устранения уязвимости на веб-сервере.
- Администрирование Windows (PowerShell, реестр, службы) для устранения уязвимости на рабочей станции.
- Администрирование Active Directory (Get-ADUser, Remove-ADUser, net user) для устранения уязвимости на контроллере домена.

1.6 Схема выполнения работы

Для каждой из трёх уязвимостей сценария выполнялась одна и та же последовательность действий (рис. 1.1).

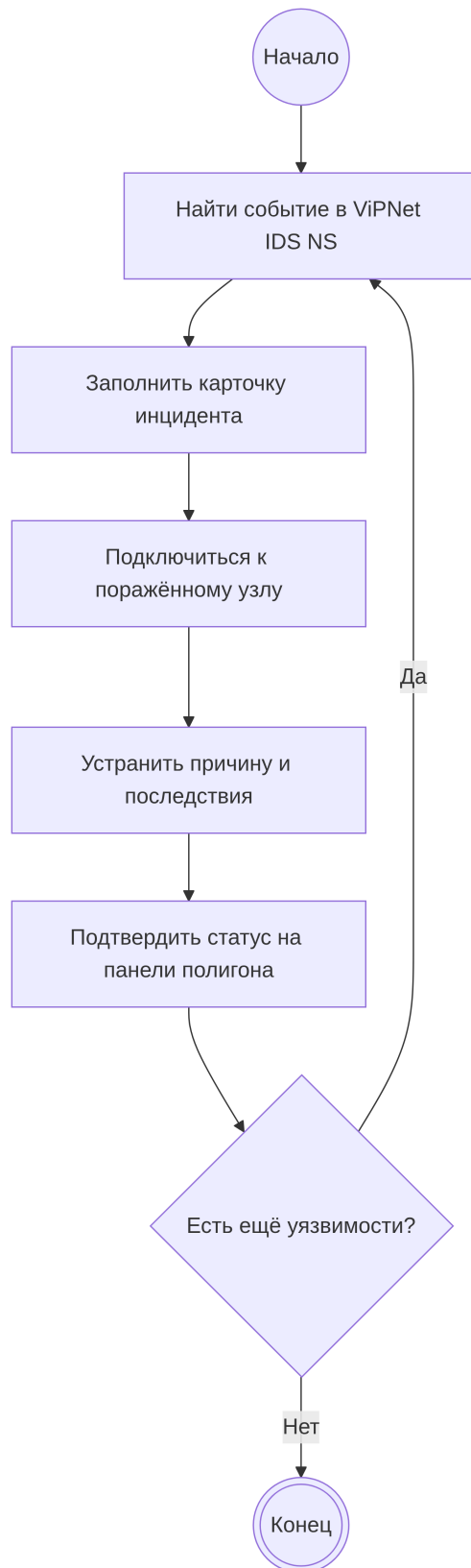


Рисунок 1.1: Блок-схема выполнения лабораторной работы

2 Теоретическая часть

2.1 Сценарий атаки

Сценарий №2 моделирует атаку внешнего злоумышленника (Kali, 195.239.174.11) на корпоративную сеть предприятия с целью захвата контроллера домена (табл. 2.1).

Таблица 2.1: Этапы атаки по сценарию №2

Этап	Действие атакующего	Источник → Цель
1	Сканирование и эксплуатация SQL-инъекции в параметре id веб-портала через sqlmap, загрузка PHP reverse shell, получение meterpreter-сессии	Kali (195.239.174.11) → Web Server PHP (195.239.174.95 / 10.10.1.20)
2	Фишинговое письмо администратору с вредоносным вложением (Metasploit payload), получение meterpreter-сессии на рабочей станции	Kali (195.239.174.11) → Administrator Workstation (10.10.4.10)

Этап	Действие атакующего	Источник → Цель
3	Перебор пароля администратора домена по RDP с уже скомпрометированного веб-сервера, добавление привилегированной учётной записи в домен	Web Server PHP (10.10.1.20) → MS Active Directory (10.10.2.10)

2.2 Топология сети полигона

Сеть полигона разделена на сегменты: периметр (Kali, внешний атакующий), DMZ 10.10.1.0/24 (Web Server PHP, CMS Drupal, Apache Tomcat, SecOnion), Data Center 10.10.2.0/24 (MS Active Directory, MS Exchange, MySQL, ViPNet EPP/IDS NS/TIAS и др.) и сегмент офисных пользователей 10.10.4.0/24 (Administrator Workstation, рабочие станции сотрудников).

2.3 Используемые средства мониторинга

ViPNet IDS NS — система обнаружения вторжений на основе сигнатурного анализа сетевого трафика, применялась для первичного обнаружения всех трёх событий атаки. **ViPNet TIAS** — система корреляционного анализа событий (аналог SIEM), используется для сопоставления разрозненных событий в единую картину инцидента.

3 Материалы и методы

Работа выполнялась на инфраструктуре киберполигона Ampire через удалённое рабочее место (Response Team, 10.140.2.153), доступное по RDP. С него выполнялось подключение по SSH (PuTTY) к веб-серверу и по RDP к рабочей станции администратора и контроллеру домена. Для анализа событий использовалась веб-консоль ViPNet IDS NS. Учётные данные для всех узлов полигона получены из файла IT-infrastructure Passwords.pdf, расположенного на рабочем столе удалённого рабочего места.

4 Выполнение лабораторной работы

4.1 Уязвимость 1. SQL-инъекция на веб-портале

4.1.1 Обнаружение

В ViPNet IDS NS по правилу ET SCAN Sqlmap SQL Injection Scan (код события 2008538, класс attempted-recon) зафиксировано сканирование веб-сервера PHP инструментом sqlmap/1.7.2 с источника 195.239.174.11 (рис. 4.1, 4.2). Непосредственно после — событие ET TROJAN Possible Metasploit Payload (рис. 4.4, 4.5), подтверждающее успешную эксплуатацию уязвимости и установление meterpreter-сессии на порту 4444.

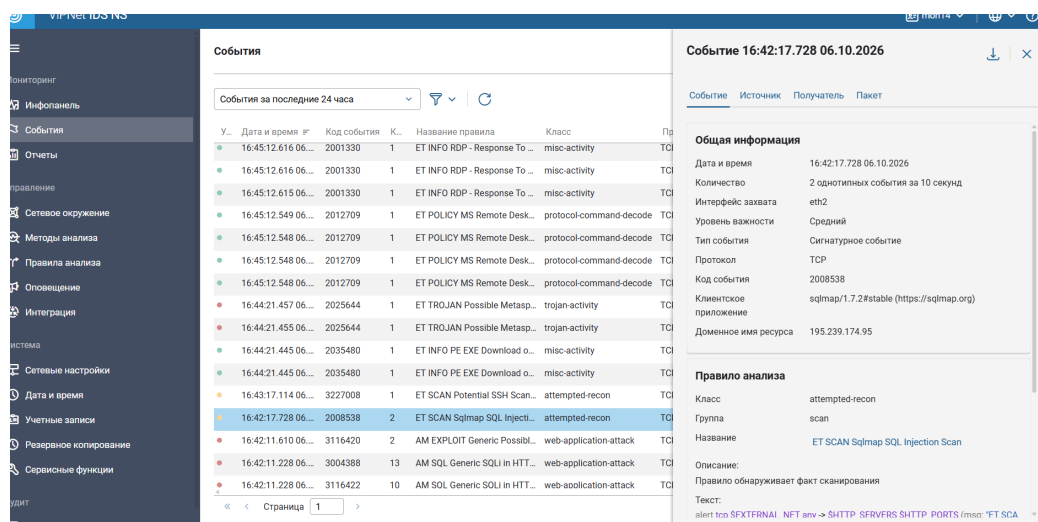


Рисунок 4.1: Событие ViPNet IDS NS: ET SCAN Sqlmap SQL Injection Scan, источник sqlmap/1.7.2

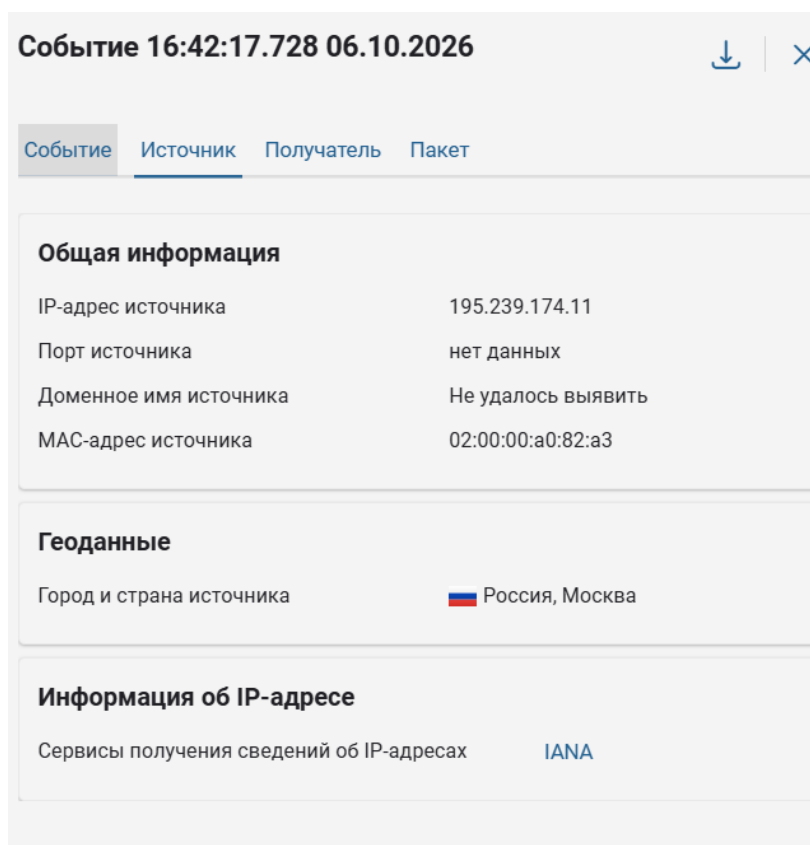


Рисунок 4.2: Источник события: IP 195.239.174.11, геолокация Россия, Москва

4.1.2 Карточка инцидента

Заведена карточка инцидента: источник — Kali (195.239.174.11), поражённый актив — Web Server PHP (10.10.1.20), индикаторы компрометации — attempted-recon/sqlmap, рекомендации — добавить валидацию входных параметров (is_numeric для id), заблокировать IP 195.239.174.11, завершить активные сессии (рис. 4.3).

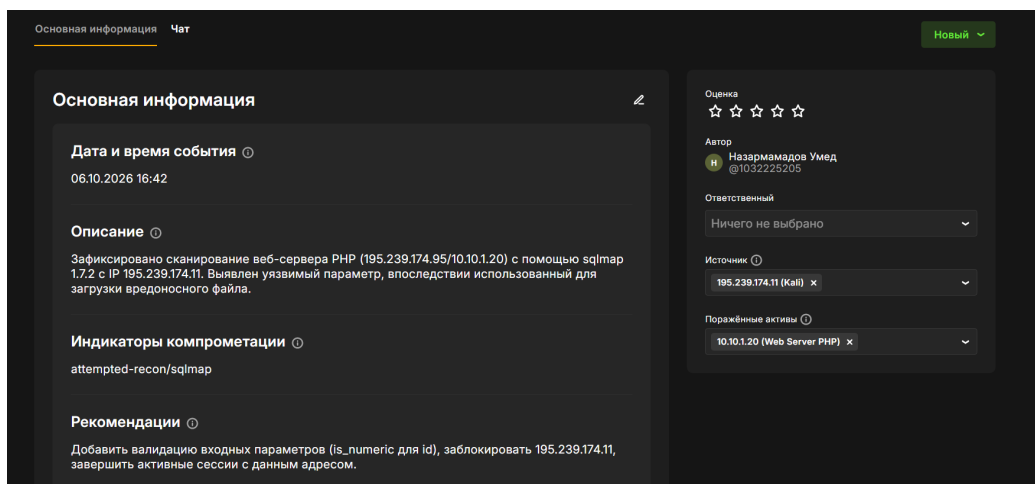


Рисунок 4.3: Карточка инцидента №1: SQL-инъекция на веб-портале

4.1.3 Устранение

На Web Server PHP (10.10.1.20) по SSH (PuTTY) выполнена эскалация до root (su -), после чего:

1. Найдена и завершена активная meterpreter-сессия атакующего по сокету:

```
ss -tp
ss -K dst 195.239.174.11 dport = 4444
```

2. Обнаружен и завершён процесс chisel — инструмент туннелирования, с помощью которого атакующий организовал проброс трафика из внутренней сети наружу (важная деталь, не описанная явно в методических указаниях, но объясняющая, каким образом внешний атакующий впоследствии получил доступ к внутреннему RDP контроллера домена).
3. В файле /var/www/html/htdocs/polygon/controllers/NewsController.php устранена причина уязвимости — отсутствие валидации параметра \$_GET['id']:

```

public function actionView()
{
    $id = $_GET['id'];
    if (!is_numeric($id)) {
        $id = 1;
    }
    $model = News::model()->findById($id);
    $comments = Comment::model()->findByAttributes(array('post_id'=>$id));
    $this->render('news/view', array('model1'=>$model, 'comments'=>$comments));
}

```

После выполнения указанных действий статусы «SQL Injection» и «Web portal meterpreter» на панели полигона изменились на «Устранено».

4.2 Уязвимость 2. Отключённая антивирусная защита на рабочей станции администратора

4.2.1 Обнаружение

В ViPNet IDS NS зафиксировано событие ET TROJAN Possible Metasploit Payload Common Construct Bind_API (from server) (код 2025644, класс trojan-activity, уровень важности «Высокий») между атакующим 195.239.174.11 (порт 444) и рабочей станцией администратора 10.10.4.10 (порт 50162) — рис. 4.4 – 4.6. Событие свидетельствует об успешной компрометации узла через фишинговое письмо с вредоносным вложением.

События

События за последние 24 часа

У...

Дата и время

F

Код события

К...

Название правила

Класс

Пр

	16:45:12.616 06...	2001330	1	ET INFO RDP - Response To ...	misc-activity	TCI
	16:45:12.616 06...	2001330	1	ET INFO RDP - Response To ...	misc-activity	TCI
	16:45:12.615 06...	2001330	1	ET INFO RDP - Response To ...	misc-activity	TCI
	16:45:12.549 06...	2012709	1	ET POLICY MS Remote Desk...	protocol-command-decode	TCI
	16:45:12.548 06...	2012709	1	ET POLICY MS Remote Desk...	protocol-command-decode	TCI
	16:45:12.548 06...	2012709	1	ET POLICY MS Remote Desk...	protocol-command-decode	TCI
	16:45:12.548 06...	2012709	1	ET POLICY MS Remote Desk...	protocol-command-decode	TCI
	16:44:21.457 06...	2025644	1	ET TROJAN Possible Metasp...	trojan-activity	TCI
	16:44:21.455 06...	2025644	1	ET TROJAN Possible Metasp...	trojan-activity	TCI
	16:44:21.445 06...	2035480	1	ET INFO PE EXE Download o...	misc-activity	TCI
	16:44:21.445 06...	2035480	1	ET INFO PE EXE Download o...	misc-activity	TCI
	16:43:17.114 06...	3227008	1	ET SCAN Potential SSH Scan...	attempted-recon	TCI
	16:42:17.728 06...	2008538	2	ET SCAN Sqlmap SQL Injecti...	attempted-recon	TCI
	16:42:11.610 06...	3116420	2	AM EXPLOIT Generic Possibl...	web-application-attack	TCI
	16:42:11.228 06...	3004388	13	AM SQL Generic SQLi in HTT...	web-application-attack	TCI
	16:42:11.228 06...	3116422	10	AM SQL Generic SOLi in HTT...	web-application-attack	TCI

«

Страница

1

»

Событие 16:44:21.457 06.10.2026

Событие

Источник

Получатель

Пакет

Общая информация

Дата и время

16:44:21.457 06.10.2026

Интерфейс захвата

eth2

Уровень важности

Высокий

Тип события

Сигнатурное событие

Протокол

TCP

Код события

2025644

Правило анализа

Класс

trojan-activity

Группа

trojan

Название

ET TROJAN Possible Metasploit Payload Common Construct Bind_API (from server)

Описание:

Правило обнаруживает сетевую активность вредоносного ПО

Текст:

alert tcp \$EXTERNAL_NET any -> \$HOME_NET any (msg: "ET TROJAN Possible Metasploit Payload Common Construct Bind_API (from server)";flow: from_server,established;content: "60 89 e5 31";content: "64 8b";distance: 1;within: 2;content: "3 0 8b";distance: 1;within: 2;content: "0c 8b 52 14 8b 72 28 0f b7 4a 26 31 ff";distance: 1;within: 13;content: "ac 3c 61 7c 02 2c 20 c1 cf 0d 01 c7 e2";within: 15;content: "52 57 8b 52 10";distance: 1;within: 5;classtype: trojan-activity;sid: 2025644;

Рисунок 4.4: Событие ViPNet IDS NS: ET TROJAN Possible Metasploit Payload Common Construct Bind_API

Событие 16:44:21.457 06.10.2026

Событие

Источник

Получатель

Пакет

Общая информация

IP-адрес источника

195.239.174.11

Порт источника

444

Доменное имя источника

Не удалось выявить

MAC-адрес источника

02:00:00:8e:35:24

Геоданные

Город и страна источника

Россия, Москва

Информация об IP-адресе

Сервисы получения сведений об IP-адресах

IANA

Рисунок 4.5: Источник события: 195.239.174.11, порт 444

17

Событие 16:44:21.457 06.10.2026	
Событие	Источник
Получатель	Пакет
Общая информация	
IP-адрес получателя	10.10.4.10
Порт получателя	50162
Доменное имя получателя	Не удалось выявить
MAC-адрес получателя	02:00:00:8e:35:26
Геоданные	
Город и страна получателя	Частный IP-адрес
Информация об IP-адресе	
Сервисы получения сведений об IP-адресах	IANA

Рисунок 4.6: Получатель события: Administrator Workstation 10.10.4.10, порт 50162

4.2.2 Карточка инцидента

Источник — Kali (195.239.174.11), поражённый актив — Administrator Workstation (10.10.4.10), индикаторы компрометации — trojan-activity/Metasploit Payload, рекомендации — завершить сессию с атакующим (netstat -ano + taskkill), включить Real-time Protection Windows Defender, провести полное сканирование узла (рис. 4.7).

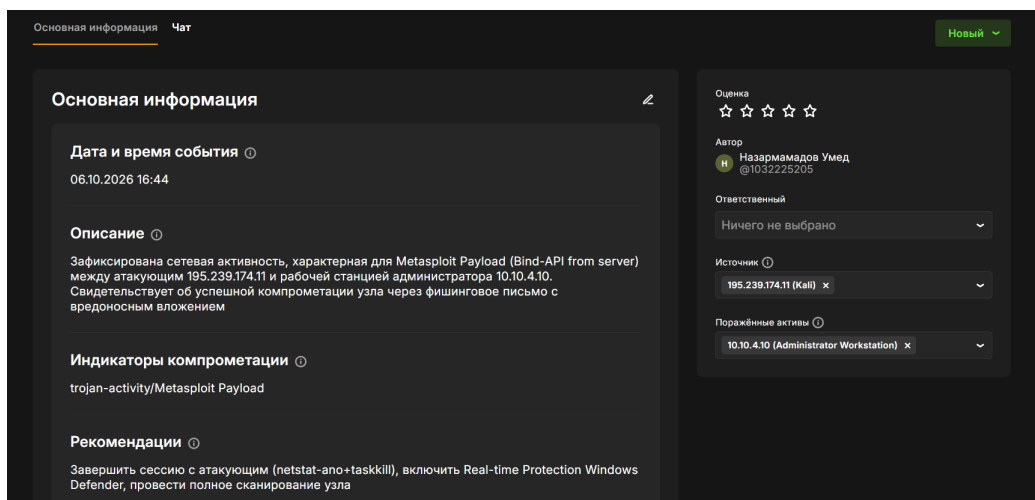


Рисунок 4.7: Карточка инцидента №2: компрометация рабочей станции администратора

4.2.3 Устранение

На Administrator Workstation (10.10.4.10) по RDP, в PowerShell от имени администратора:

1. Обнаружена и завершена сессия атакующего:

```
netstat -ano  
taskkill /f /pid 7288
```

2. Проверено состояние защиты — обнаружено, что политикой был отключён как Windows Defender (DisableAntiSpyware), так и Real-time Protection (DisableRealtimeMonitoring = True):

```
Get-MpPreference | Select DisableRealtimeMonitoring, DisableAntiSpyware
```

3. Устранена причина — удалены запрещающие политики из реестра, перезапущена служба защиты:

```
REG DELETE "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender" /v DisableAntiSpy
REG DELETE "HKLM\SOFTWARE\Policies\Microsoft\Windows Defender\Real-Time Protection" /v
Start-Service WinDefend
```

4. Подтверждено восстановление защиты:

```
Get-MpComputerStatus | Select RealTimeProtectionEnabled, AntivirusEnabled
```

Результат: RealTimeProtectionEnabled = True, AntivirusEnabled = True.

После завершения сессии атакующего последствие «Admin meterpreter» на панели полигона сразу изменилось на «Устранено». Статус самой уязвимости временно отображался как «Сервер недоступен» из-за потери связи агента мониторинга с узлом после перезапуска служб — технически уязвимость была устранена и подтверждена показанными выше командами до наступления этого сбоя.

4.3 Уязвимость 3. Перебор пароля администратора домена и добавление привилегированного пользователя

4.3.1 Обнаружение

В ViPNet IDS NS по правилу ET POLICY MS Remote Desktop Administrator Login Request (код 2012709, класс protocol-command-decode) зафиксировано 29 однотипных событий за 10 секунд — характерный признак перебора пароля (brute-force) по RDP (рис. 4.8 – 4.10). Источник — уже скомпрометированный веб-сервер (10.10.1.20), получатель — контроллер домена (10.10.2.10, порт 3389).

События

События за последние 24 часа

У...	Дата и время	Код события	К...	Название правила	Класс	Пр
	16:51:28.770 06...	2100538	1	GPL NETBIOS SMB IPC\$ uni...	protocol-command-decode	TCI
	16:50:58.697 06...	2100538	1	GPL NETBIOS SMB IPC\$ uni...	protocol-command-decode	TCI
	16:50:28.644 06...	2100538	1	GPL NETBIOS SMB IPC\$ uni...	protocol-command-decode	TCI
	16:49:58.576 06...	2100538	1	GPL NETBIOS SMB IPC\$ uni...	protocol-command-decode	TCI
	16:48:00.643 06...	3227018	1	ET SCAN Behavioral Unusual...	network-scan	TCI
	16:45:49.352 06...	2025644	1	ET TROJAN Possible Metasp...	trojan-activity	TCI
	16:45:49.351 06...	2025644	1	ET TROJAN Possible Metasp...	trojan-activity	TCI
	16:45:49.343 06...	2035480	1	ET INFO PE EXE Download o...	misc-activity	TCI
	16:45:49.343 06...	2035480	1	ET INFO PE EXE Download o...	misc-activity	TCI
	16:45:23.617 06...	2001330	18	ET INFO RDP - Response To ...	misc-activity	TCI
	16:45:23.549 06...	2012709	29	ET POLICY MS Remote Desk...	protocol-command-decode	TCI
	16:45:12.994 06...	3007790	1	AM SCAN Microsoft Window...	unsuccessful-user	TCI
	16:45:12.964 06...	3227018	1	ET SCAN Behavioral Unusual...	network-scan	TCI
	16:45:12.964 06...	3227023	1	ET SCAN Behavioral Unusual...	misc-activity	TCI
	16:45:12.616 06...	2001330	1	ET INFO RDP - Response To ...	misc-activity	TCI

«

<

Страница 1

>

»

Событие 16:45:23.549 06.10.2026

Событие

Источник

Получатель

Пакет

Общая информация

Дата и время

16:45:23.549 06.10.2026

Количество

29 однотипных событий за 10 секунд

Интерфейс захвата

eth2

Уровень важности

Низкий

Тип события

Сигнатурное событие

Протокол

TCP

Код события

2012709

Правило анализа

Класс

protocol-command-decode

Группа

policy

Название

ET POLICY MS Remote Desktop Administrator Login Request

Описание:

Сигнатуры возможного нарушения политики информационной безопасности

Текст:

alert tcp \$EXTERNAL_NET any -> \$HOME_NET 3389 (msg: "ET POLICY MS Remote Desktop Administrator Login Request";flow: established,to_server;content: "03 0 0 00";depth: 3;content: "e0 00 00 00 00 00";distance: 2;within: 6;content: "Cookie"

Рисунок 4.8: Событие ViPNet IDS NS: ET POLICY MS Remote Desktop Administrator Login Request, 29 событий за 10 секунд

Событие

Источник

Получатель

Пакет

Общая информация

IP-адрес источника

10.10.1.20

Порт источника

нет данных

Доменное имя источника

Не удалось выявить

MAC-адрес источника

нет данных

Геоданные

Город и страна источника

Частный IP-адрес

Информация об IP-адресе

Сервисы получения сведений об IP-адресах

IANA

Рисунок 4.9: Источник события: 10.10.1.20 (ранее скомпрометированный Web Server PHP)

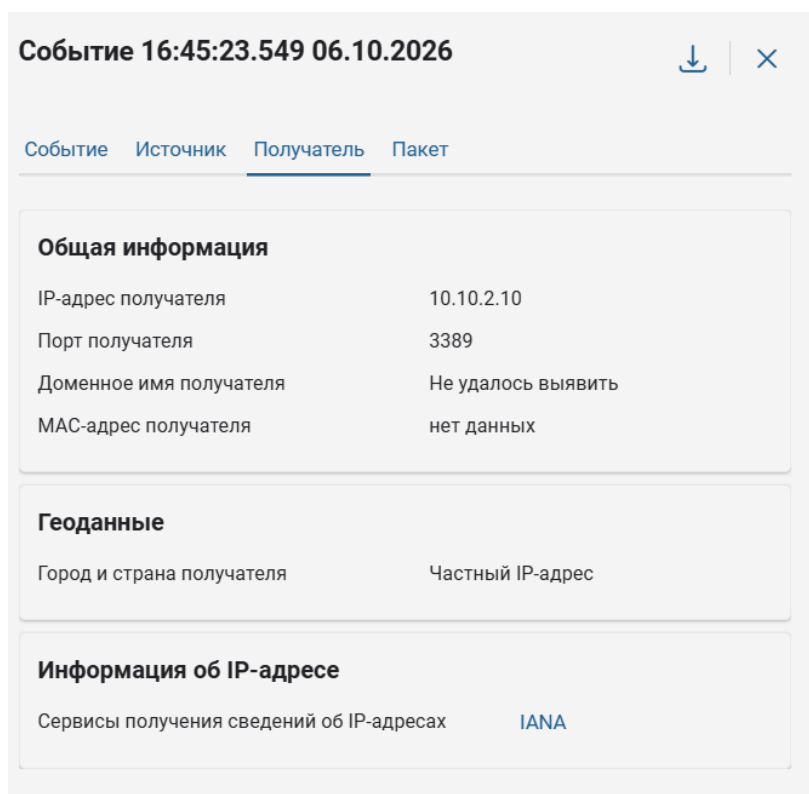


Рисунок 4.10: Получатель события: MS Active Directory 10.10.2.10, порт 3389

4.3.2 Карточка инцидента

Источник — Web Server PHP (10.10.1.20), поражённый актив — MS Active Directory (10.10.2.10), индикаторы компрометации — protocol-command-decode/MS Remote Desktop Administrator Login Request/brute-force, рекомендации — сменить пароль администратора AD, проверить и удалить все добавленные нарушителем учётные записи, ограничить доступ по RDP к контроллеру домена только с доверенных узлов (рис. 4.11).

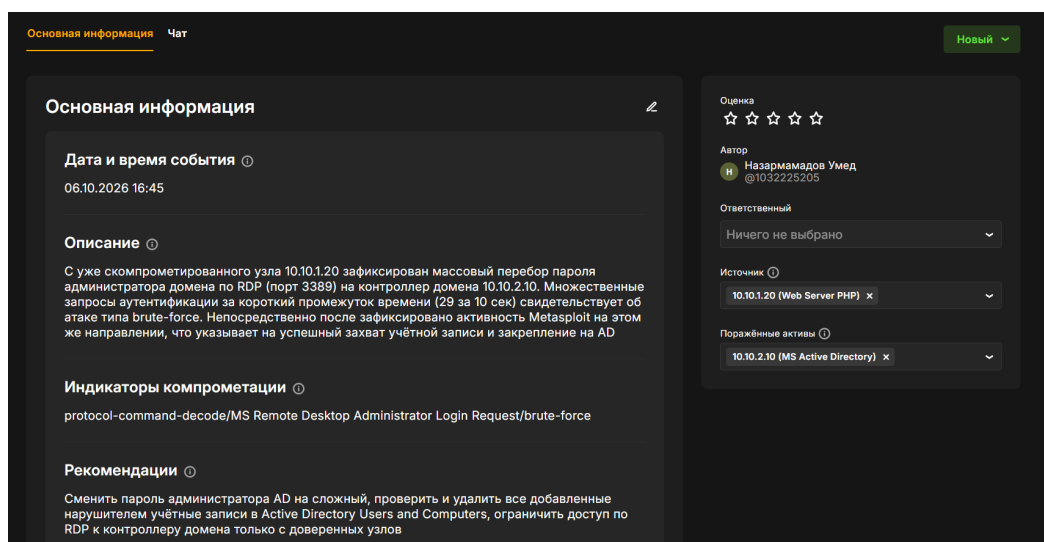


Рисунок 4.11: Карточка инцидента №3: перебор пароля администратора домена

4.3.3 Устранение

На MS Active Directory (10.10.2.10) по RDP, в PowerShell от имени администратора:

1. Через Active Directory Users and Computers обнаружена нелегитимная учётная запись hacker.
2. Проверено членство в привилегированных группах; учётная запись удалена из домена:

```
Remove-ADUser -Identity hacker -Confirm:$false
Get-ADUser -Filter {SamAccountName -eq "hacker"}
```

Повторный запрос вернул пустой результат — учётная запись удалена.

3. Сменён пароль администратора домена, скомпрометированный перебором:

```
net user Administrator *
```

После выполнения этих действий статусы «AD Admin Password» и «AD user» на панели полигона изменились на «Устранено».

5 Результаты

По итогам расследования и реагирования на панели «Уязвимости и последствия» киберполигона зафиксированы следующие статусы (табл. 5.1):

Таблица 5.1: Итоговые статусы устранения уязвимостей

Уязвимость / последствие	Поражённый узел	Статус
SQL Injection	Web Server PHP (10.10.1.20)	Устранено
Web portal meterpreter	Web Server PHP (10.10.1.20)	Устранено
Уязвимость 2 (Windows Defender)	Administrator Workstation (10.10.4.10)	Устранено техниче- ски; статус панели на момент фиксации — «Сервер недосту- пен»
Admin meterpreter	Administrator Workstation (10.10.4.10)	Устранено

Уязвимость / последствие	Поражённый узел	Статус
AD Admin Password	MS Active Directory (10.10.2.10)	Устранено
AD user	MS Active Directory (10.10.2.10)	Устранено

Для каждого из трёх этапов атаки обнаружено исходное событие в ViPNet IDS NS, заведена и заполнена карточка инцидента с источником, поражённым активом, индикаторами компрометации и рекомендациями, выполнено техническое устранение причины на поражённом узле.

6 Обсуждение результатов

Все три уязвимости сценария последовательно соответствуют реальной цепочке компрометации: эксплуатация веб-уязвимости на периметре → закрепление на внутреннем узле через фишинг → горизонтальное перемещение и захват контроллера домена методом перебора пароля. Такая последовательность типична для целенаправленных атак (APT) на корпоративные сети и подчёркивает важность эшелонированной защиты: устранение только одной уязвимости (например, патч SQL-инъекции) не остановило бы атакующего, уже закрепившегося на рабочей станции администратора.

Отдельного внимания заслуживает обнаруженный в ходе устранения первой уязвимости процесс `chisel` на веб-сервере — инструмент туннелирования, не упомянутый явно в методических указаниях, но объясняющий технический механизм, с помощью которого внешний атакующий (195.239.174.11) смог инициировать RDP-перебор против внутреннего адреса контроллера домена (10.10.2.10) в третьем эпизоде: трафик пробрасывался через скомпрометированный веб-сервер как через точку поворота (*pivot*).

Временная недоступность агента мониторинга на Administrator Workstation после перезапуска службы Windows Defender — не следствие ошибки в действиях по реагированию (что подтверждается командой `Get-MpComputerStatus`, выполненной непосредственно до потери связи), а особенность инфраструктуры полигона.

7 Заключение

- Цель работы достигнута: проведено полное расследование трёхэтапного инцидента на киберполигоне Amprige с обнаружением, документированием и устранением всех предусмотренных сценарием уязвимостей.
- Для каждого этапа атаки (SQL-инъекция, компрометация рабочей станции через фишинг, захват контроллера домена перебором пароля) выполнен полный цикл: обнаружение по данным ViPNet IDS NS → заполнение карточки инцидента → устранение технической причины → подтверждение статуса.
- Дополнительно выявлен и нейтрализован инструмент туннелирования (chisel), использованный атакующим для организации pivot-доступа во внутреннюю сеть — деталь, важная для полного понимания механизма атаки.
- Рекомендации для реальной инфраструктуры: внедрить валидацию входных параметров на уровне веб-приложений, обеспечить политику запрета отключения антивирусной защиты обычными пользователями (GPO), ограничить RDP-доступ к контроллерам домена списком доверенных узлов и включить блокировку учётных записей после нескольких неудачных попыток входа.